

РОБОЧИЙ ДОКУМЕНТ / РЕДАКЦІЯ ВЛАСНИКА ПРОЄКТУ

Як університет підключається до и.Освіта

Тут зафіксовано не абстрактне «API для освіти», а конкретний обмін, який уже читає цей backend: студент, розклад, оцінки, календар, баланс, оплати та знижки.

Версія: 1.0 draft

Мова даних: UTF-8

Формат: JSON / RSS

Оновлено: 05.09.2026

WORKING COPY

1. Навіщо я зібрав цей документ

Щоб на першій зустрічі з університетом не пояснювати систему «на пальцях». IT-служба бачить контракт і вимоги до мережі, власник даних — перелік полів, служба безпеки — точки доступу, а команда u.Освіта — однакові критерії приймання.

Моя межа чесності. Те, що реально знайдено в коді, позначено як поточна реалізація. Те, що потрібно для нормальної багатоуніверситетської роботи, позначено як ціль. Ці речі не змішані навмисно.

Університет надає

Захищений API до своєї інформаційної системи та тестові дані без персональних даних реальних студентів.

u.Освіта виконує

Періодичне читання даних, нормалізацію, збереження у PostgreSQL та надання даних застосунку.

Дані не змішуються

Кожен запис має належати визначеному університету; доступ контролюється на backend.

Підхід до змін

Контракт версіонується. Несумісні зміни випускаються лише в новій major-версії.

2. Де ми зараз — без презентаційного глянцю

Область	Поточна реалізація	Цільова модель
Провайдер	Один MAUP-подібний API	Окремий адаптер і конфігурація для кожного університету
Credentials	Спільні значення в environment	Зашифровані credentials на рівні університету
Авторизація провайдера	HTTP Basic Auth	mTLS або OAuth 2.0 Client Credentials; Basic — лише як сумісний варіант
Історія запусків	Зберігається переважно поточний стан	Незмінний журнал кожного запуску та спроби
Ізоляція адміністраторів	Глобальна роль ADMIN	Доступ адміністратора лише до дозволених organizationId
Branding	Відсутній як модель університету	Логотип, кольори, назва, функції та контакти для кожного tenant

Важливо. Цей документ описує фактичні поля поточного адаптера й одночасно фіксує вимоги, які треба виконати перед підключенням кількох університетів у production. Позначені цільові функції не слід вважати вже реалізованими.

3. Архітектура обміну



u.Освіта працює як клієнт API університету. Університет не повинен напряму підключатися до PostgreSQL u.Освіта. Фоновий worker отримує завдання через Redis, викликає API університету, перевіряє відповідь і записує нормалізовані дані.

Рекомендована мережна модель: allowlist IP, TLS 1.2+, окремий service account, read-only доступ, обмеження частоти, correlation ID і журнал звернень.

4. Повний каталог даних платформи

Домен	Сутності	Власник / джерело	Чутливість
Особа	ПІБ, телефон, email, ІПН, підтвердження контактів, роль	Користувач + університет	Висока, персональні дані
Студент	Зовнішній ID, курс, семестр, форма, спеціальність, статус, період навчання	Університет	Висока
Структура	Університет, факультет/інститут, кафедра, група, дисципліна	Університет	Звичайна
Інфраструктура	Корпуси, адреси, координати, аудиторії	Університет	Звичайна
Навчання	Розклад, екзамени, викладачі, оцінки, кредити, навчальний календар	Університет	Висока
Оплата навчання	Баланс, історія оплат, знижки, пільги	Університет	Висока, фінансова
Банківські платежі	Платіж, стан транзакції, шаблон, маскований PAN, токен картки	Процесинг	Критична
Комунікації	Новини, посилання, дата публікації	Університет	Звичайна
Безпека	JWT, OTP, невдалі входи, блокування	u.Освіта	Критична
Операції	Стани синхронізації, cron, помилка, лічильник спроб	u.Освіта	Службова

Правила даних

- Зовнішній `student\_id` має бути стабільним і не перевикористовуватися.

- Дати передаються в ISO 8601; дата без часу — `YYYY-MM-DD`, час — із часовим поясом.
- Телефон передається в міжнародному форматі без пробілів.
- Порожнє значення — `null`, а не порожній рядок, якщо поле допускає відсутність.
- Грошові значення мають супроводжуватися валютою у цільовій версії контракту.
- Усі рядки — UTF-8; назви не повинні містити HTML або виконуваний код.

5. API, яке надає університет

Базовий URL і credentials узгоджуються під час підключення. Поточний адаптер надсилає JSON через `POST` і використовує Basic Auth. Доступні інтерактивний Swagger API та OpenAPI YAML.

Метод	Шлях	Призначення	Ключ запиту
POST	/studentinfo	Пошук студентських профілів	phone_number або student_id
POST	/saldo	Баланс навчання	student_id
POST	/schedule	Розклад і екзамени	student_id , semestr , опційно zes_schedule
POST	/marks	Оцінки	student_id
POST	/calgraph	Навчальний календар	student_id
POST	/payments	Історія оплат	student_id
POST	/discounts	Знижки та пільги	student_id
GET	/ RSS URL	Новини університету	Без тіла

Стандарт відповіді та HTTP-коди

Код	Значення	Повтор
200	Запит оброблено; порожній масив означає, що даних немає	Ні
400	Невалідне тіло запиту	Лише після виправлення
401/403	Помилка автентифікації або прав	Ні, потрібна ескалація
404	Студента не знайдено	Ні
409	Конфлікт версії/стану	Після повторного читання
429	Перевищено rate limit	Так, за `Retry-After`
500	Внутрішня помилка університету	Так, exponential backoff
503	Тимчасова недоступність	Так, exponential backoff

6. Основні приклади

Профіль студента

```
POST /studentinfo
Authorization: Basic ***
Content-Type: application/json

{ "phone_number": "380501112233" }
```

```
[
  {
    "student_id": 10001,
    "last_name": "Коваленко",
    "first_name": "Анна",
    "middle_name": "Олександрівна",
    "nsb": "Контракт 2026-001",
    "group": "ІПЗ-31",
    "course": 3,
    "institute": "Факультет інформаційних технологій",
    "level_learn": "Бакалавр",
    "form_learn": "Денна",
    "speciality": "Інженерія програмного забезпечення",
    "specialization": "Програмні системи",
    "qualification": "Бакалавр",
    "price": 32000,
    "price_pay_period": "Семестр",
    "price_pay_type": "Контракт",
    "sex": "F",
    "ipn": "0000000000",
    "phone_number": "380501112233",
    "education_start": "2024-09-01",
    "education_end": "2028-06-30"
  }
]
```

Розклад

```
POST /schedule
{ "student_id": 10001, "semestr": 5 }
```



```
[
  {
    "student_id": 10001,
    "semestr": 5,
    "zes_schedule": 0,
    "from_date": "2026-09-01",
    "to_date": "2026-12-20",
    "schedule": [
      {
        "pair_idx": 1,
        "from_time": "09:00",
        "to_time": "10:30",
        "pair_kind": "Лекція",
        "pair_subject": "Архітектура ПЗ",
        "pair_auditorium": "305",
        "pair_prepod": "Іваненко О. М.",
        "subject_id": 301,
        "auditorium_id": 305,
        "prepod_id": 501,
        "day_date": "2026-09-07"
      }
    ]
  }
]
```

Історія оплат

```
[
  {
    "student_id": 10001,
    "payments": [
      {
        "date": "2026-09-01",
        "operation_name": "Оплата за навчання",
        "document_type": "Банківська квитанція",
        "payment_value": 16000
      }
    ]
  }
]
```

7. Синхронізація

Набір	Поточний тип	Рекомендована частота	Ідемпотентний ключ
Розклад	STUDENT_SCHEDULES_SYNC	Кожні 6 годин + вручну	student + semester + event
Екзамени	STUDENT_EXAMS_SYNC	Щодня; частіше під час сесії	student + semester + event
Оцінки	STUDENT_SCORES_SYNC	Щодня	organization + student + discipline + semester
Навчальний план	STUDENT_EDUCATION_PLAN_SYNC	Щодня	student + semester + type + dates
Баланс	EDUCATION_PAYMENT_STATE_SYNC	Кілька разів на день	student
Історія оплат	STUDENT_PAYMENT_HISTORY_SYNC	Щодня	student + date + document
Знижки	STUDENT_PAYMENT_DISCOUNTS_SYNC	Щодня	student + discount ID
Новини	ORGANIZATION_ARTICLES_SYNC	Кожні 30–60 хвилин	organization + hash/link

Повторний запуск із тим самим набором даних не повинен створювати дублікати. Видалення даних у джерелі потребує узгодженої стратегії: tombstone, ознака `deleted`, повний snapshot або окремий endpoint змін.

PostgreSQL зберігає поточний стан синхронізації, але не повну історію кожної спроби. Для production-аудиту потрібна окрема сутність SynchronizationRun.

8. Безпека і персональні дані

Обов'язкові вимоги

- TLS 1.2 або новіший із валідним сертифікатом. Вимикати перевірку сертифіката у production заборонено.
- Окремий service account для u.Освіта з мінімальними read-only правами.
- Ротація секретів, журнал доступу та процедура відкликання.
- Не передавати passwords, повні реквізити карток або CVV.
- Маскувати ІПН, телефон та фінансові дані у логах.
- Обмежити API за IP, rate limit і максимальним розміром відповіді.
- Визначити строки зберігання, підставу обробки й процедуру видалення персональних даних.
- Тестове середовище не повинно містити реальних персональних даних.

Рекомендовані заголовки

```
X-Correlation-Id: UUID
X-Request-Timestamp: 2026-09-05T12:00:00Z
Content-Type: application/json
Accept: application/json
```

Поточний ризик: існуючий MAUP-клієнт використовує `rejectUnauthorized: false`. Перед реальною інтеграцією перевірку TLS потрібно обов'язково ввімкнути.

9. Ізоляція університетів в одній базі

Одна PostgreSQL може безпечно обслуговувати багато університетів, якщо кожен доменний запис однозначно належить tenant. Фільтрації лише у frontend недостатньо.

```
JWT адміністратора
→ дозволені organizationId
→ tenant middleware
→ примусовий organizationId у запиті
→ Prisma
→ PostgreSQL
```

Контроль	Вимога
Адміністратори	Окрема таблиця доступів user ↔ organization із роллю
Запити	Backend сам додає tenant filter, не довіряє organizationId від браузера
Інтеграції	Окремі URL, credentials і timeout для кожного університету
Черги	Job ID містить organizationId; worker повторно перевіряє належність
Файли	Окремий namespace для логотипів і документів
Аудит	Кожна адміністративна дія містить actorId та organizationId
Тести	Спроба адміністратора А прочитати tenant В завжди повертає 403

10. Формат помилок і діагностика

Цільовий стабільний формат:

```
{
  "error": {
    "code": "STUDENT_NOT_FOUND",
    "message": "Student was not found",
    "correlationId": "3aa8...",
    "retryable": false,
    "details": []
  }
}
```

и.Освіта зараз має власні коди на кшталт `VALIDATION_ERROR`, `ANOTHER_SERVICE_EXCEPTION`, `STD_E002` і `ORG_E001`. Для університетського API потрібна окрема погоджена таблиця кодів, незалежна від тексту повідомлення.

Ідентифікатор запису SyncStatus не є ідентифікатором конкретного запуску або помилки. Для розслідування потрібні job ID, correlation ID та історія спроб.

11. Рекомендований SLA

Показник	Рекомендація
Доступність	Не менше 99,5% на місяць, виключаючи погоджені роботи
Час відповіді	p95 ≤ 2 секунди, p99 ≤ 5 секунд
Timeout клієнта	10 секунд у поточній реалізації; бажано конфігурувати на tenant
Rate limit	Погоджується за кількістю студентів; відповідь 429 містить Retry-After
RPO	Не більше інтервалу відповідної синхронізації
RTO	До 4 годин для навчальних даних; окремо погодити критичні фінансові потоки
Сповіщення про роботи	Не менше ніж за 3 робочі дні
Критичний інцидент	Підтвердження отримання до 30 хвилин

12. Процес підключення університету

1. **Власники.** Призначити відповідальних за бізнес-дані, API, безпеку та підтримку.
2. **Scope.** Визначити доступні модулі: профіль, розклад, оцінки, план, оплати, новини.
3. **Mapping.** Заповнити таблицю відповідності полів локальної системи контракту u.Освіта.
4. **Тестовий API.** Надати endpoint, credentials, allowlist і синтетичних студентів.
5. **Contract tests.** Перевірити OpenAPI, типи, nullable-поля, дати, кодування й помилки.
6. **Навантаження.** Узгодити rate limit і протестувати повну синхронізацію.
7. **Безпека.** Провести review TLS, секретів, логування та персональних даних.
8. **UAT.** Представники університету звіряють дані у застосунку.
9. **Production.** Окремі production credentials, план запуску і rollback.
10. **Супровід.** Моніторинг, SLA, контакти та процедура змін.

13. Критерії приймання

Перевірка	Очікуваний результат
Пошук існуючого студента	Повертається повний і правильний профіль
Невідомий студент	404 або погоджений порожній результат без 500
Кирилиця та апостроф	UTF-8 не пошкоджується
Порожні optional-поля	Передається `null`, клієнт не падає
Повторний запит	Дані стабільні, дублікати не виникають
Зміна розкладу	Подія оновлюється, а не дублюється
Timeout/503	u.Освіта повторює запит із backoff і фіксує помилку
Ізоляція tenant	Дані одного університету недоступні іншому
Відкликані credentials	Доступ припиняється, секрет не з'являється у логах
Повна вибірка	Узгоджений обсяг обробляється в межах SLA

14. API u.Освіта для застосунку та адміністрування

Ці endpoints надає сама u.Освіта. Вони не замінюють Provider API університету.

Префікс	Призначення	Приклади
<code>/v1/auth</code>	Реєстрація, OTP, login, refresh, відновлення	<code>/login</code> , <code>/refresh-tokens</code>
<code>/v1/students</code>	Профіль і навчальні дані	<code>/:id/schedule</code> , <code>/:id/scores</code>
<code>/v1/educations</code>	Структура університету	organizations, departments, cafedras, groups
<code>/v1/payments</code>	Платежі та callback	templates, paymentRef, purchase
<code>/v1/tokenization</code>	Токени карток	card-tokens
<code>/admin/api</code>	Моніторинг і керування	students, organizations, sync-management

Інтерактивний Swagger backend доступний у development за шляхом `/v1/docs/` . Перед передачею зовнішнім сторонам його слід очистити від адміністративних і внутрішніх операцій та зафіксувати версію.

15. Відомі обмеження поточного коду

- Конфігурація MAUP є глобальною, а не окремою для кожного університету.
- Перевірку TLS-сертифіката зовнішнього API вимкнено.
- Формати відповідей описані TypeScript-типами, але runtime validation відповідей провайдера відсутня.
- Назви на кшталт `semestr` і `discaunt_name` містять історичні помилки та мають бути стабілізовані версією контракту.
- Відповіді помилок зовнішнього API перетворюються переважно на загальний ``503``.
- Немає повної історії запусків синхронізації.
- Немає гарантованої транзакції між PostgreSQL і BullMQ.
- Адміністративні права ще не ізольовані за університетом.
- Branding і feature flags університету не представлені окремими моделями.
- Prisma-схема та міграції мали розбіжність щодо статусу ``SUSPENDED``.

Перед укладанням інтеграційної угоди потрібні: затверджений OpenAPI 1.0, tenant-модель, contract tests, перевірка TLS, правила видалення даних і production SLA.

16. Супровід і керування змінами

Для кожного університету в інтеграційному паспорті необхідно заповнити:

Власник бізнес-даних	ПІБ, роль, email, телефон
Технічна підтримка університету	Групова адреса, телефон, години роботи
Підтримка u.Освіта	Групова адреса, escalation contact
Test / production endpoints	Заповнюються у захищеному реєстрі, не в цьому документі
Планові роботи	Канал і мінімальний строк попередження
Версія контракту	Major.minor.patch і дата введення

Зміна назви поля, типу, обов'язковості або семантики вважається несумісною. Нові optional-поля можна додавати в міног-версії. Університет та u.Освіта повинні підтримувати попередню major-версію протягом погодженого перехідного періоду.